

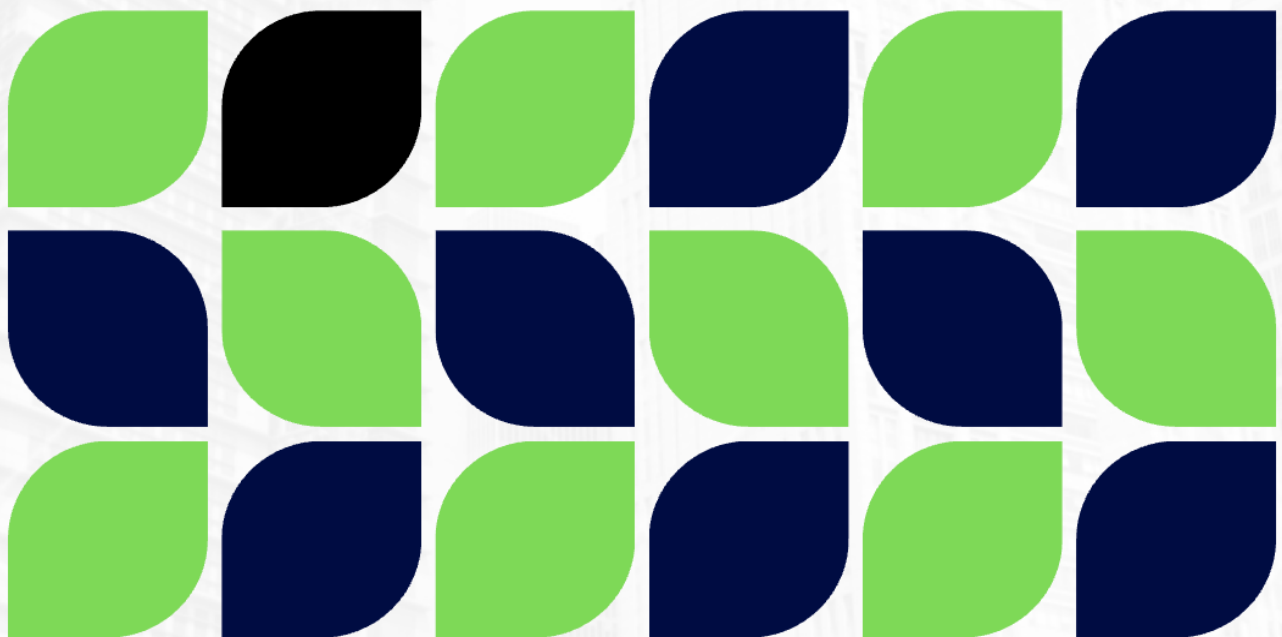
2025

Comparative Incident & Security Breach Analysis

Assignment title: Comparative Incident & Security Breach Analysis

Prepared By :

Shirizane Magadla



Comparative Incident & Security Breach Analysis

Prepared for Executives

Student Name: Shirizane Magadla

Student ID: 2025/GRC/10280

Course: GRC104 - Compliance Frameworks and Legal Requirements

Instructor: Miss Sharon

Date: 02/11/2025

Executive Summary

This report delivers an in-depth comparative analysis of two major cybersecurity incidents that have shaped the South African risk landscape in the past three years: the 2023 ransomware attack on Transnet SOC Ltd and the 2022 data breach at the Department of Justice and Constitutional Development (DoJ&CD). Both incidents underscore the urgent need for robust cybersecurity governance, proactive risk management, and a culture of security awareness at all organizational levels. The analysis explores the context, causes, and consequences of each incident, drawing out key lessons and providing a prioritized roadmap for remediation. The recommendations are designed to help executive leadership make informed decisions that will strengthen organizational resilience, protect sensitive data, and maintain public trust.

1. Incident A: Transnet SOC Ltd Ransomware Attack (2023)



1.1 Organization Overview

Transnet SOC Ltd is South Africa's largest state-owned logistics company, responsible for managing the country's ports, railways, and pipelines. With approximately 55,000 employees and a critical role in national and regional trade, Transnet's operations are foundational to the South African economy. Its infrastructure supports not only domestic commerce but also international trade routes, making it a high-value target for cybercriminals.

1.2 Incident Summary

In July 2023, Transnet fell victim to a sophisticated ransomware attack. The attackers gained access to the company's internal network, encrypted vital operational systems, and demanded a ransom for decryption keys. The attack led to the shutdown of several major ports, causing significant delays in cargo handling and disrupting supply chains across the country. The incident quickly escalated from an IT issue to a national crisis, with ripple effects felt throughout the economy.

1.3 Compliance and Regulatory Context

Transnet is subject to several regulatory frameworks:

- **POPIA (Protection of Personal Information Act):** Governs the processing and protection of personal data.
- **Cybercrimes Act (2020):** Criminalizes unauthorized access and cyber extortion.
- **King IV Corporate Governance:** Sets out principles for risk management and IT governance.
- **ISO 27001:** Provides a framework for information security management, which Transnet is working to fully implement.

1.4 Root Causes

The root causes of the incident were multifaceted:

- **Technical:** The attackers exploited unpatched vulnerabilities and weak network segmentation, allowing lateral movement within the network. Endpoint detection and response (EDR) tools were either absent or not properly configured.
- **Process:** The incident response plan was outdated and had not been tested in a real-world scenario, leading to delays in containment and recovery.
- **Human Factors:** The initial breach vector was a phishing email, indicating insufficient employee training and awareness regarding social engineering threats.

1.5 Detection and Disclosure

The attack was first detected internally when port operations began to fail and IT systems became unresponsive. Within 24 hours, Transnet's leadership decided to publicly disclose the incident, notify regulators, and communicate with customers and stakeholders. This transparency helped manage public perception but also highlighted the scale of the disruption.

1.6 Response and Consequences

Transnet's immediate response included isolating affected systems, engaging external cybersecurity experts, and launching a forensic investigation. The company prioritized restoring critical operations, particularly at major ports. The Chief Security Officer resigned, and a new Chief Information Security Officer was appointed to drive the recovery and future strategy. As of October 2025, regulatory investigations are ongoing, but no fines have been issued.

1.7 Impact

- **Financial:** The estimated direct and indirect losses exceeded R1.7 billion, factoring in operational downtime, recovery costs, and lost revenue.
- **Operational:** The attack caused major delays in port activities, affecting imports, exports, and the broader supply chain.
- **Reputational:** The incident attracted significant media attention and eroded trust among international partners and customers.
- **Data Exposure:** While there is no evidence of large-scale personal data theft, some operational and employee data were exposed.

1.8 Lessons Learned & Remediation

- **Short-term:** Immediate patching of critical systems, deployment of advanced endpoint protection, and urgent employee phishing awareness training.
- **Medium-term:** Redesign of network segmentation, regular incident response drills, and improved backup strategies.
- **Long-term:** Comprehensive upgrade of legacy systems, full alignment with ISO 27001, and continuous security monitoring.

1.9 Accountability

An internal review is ongoing to determine individual accountability. No criminal charges have been filed, and there was no whistleblower involvement in this case.

2. Incident B: Department of Justice & Constitutional Development Data Breach (2022)



2.1 Organization Overview

The Department of Justice and Constitutional Development (DoJ&CD) is a national government department with approximately 22,000 employees. It is responsible for the administration of justice, including court operations, legal services, and the protection of constitutional rights. The department manages sensitive legal and personal data, making it a prime target for cyberattacks.

2.2 Incident Summary

In September 2022, the DoJ&CD experienced a ransomware attack that disrupted digital court systems nationwide. The attackers encrypted critical data and systems, rendering many services inaccessible. There were also concerns that sensitive legal and personal data may have been exfiltrated, raising the stakes for both the department and affected individuals.

2.3 Compliance and Regulatory Context

The DoJ&CD is governed by:

- **POPIA:** Mandates the protection of personal information.
- **Minimum Information Security Standards (MISS):** Sets baseline security requirements for government departments.
- **Cybercrimes Act (2020):** Addresses unauthorized access and data breaches.

2.4 Root Causes

- **Technical:** The department's systems were vulnerable due to weak password policies and outdated anti-malware software.
- **Process:** Backup and recovery procedures were incomplete, and there was a lack of regular vulnerability assessments.
- **Human Factors:** Staff had limited cybersecurity training, and there were no regular security drills to prepare for such incidents.

2.5 Detection and Disclosure

The attack was detected internally on the same day it began, as staff lost access to digital court systems. Public disclosure followed three days later, with notifications sent to the Information Regulator and affected parties. The department's communication was generally transparent, but the delay in public disclosure drew some criticism.

2.6 Response and Consequences

The department responded by resetting passwords, restoring systems from backups where possible, and engaging external cybersecurity consultants. The IT Director was suspended pending the outcome of an internal investigation. No regulatory fines have been issued as of October 2025, but the incident remains under review.

2.7 Impact

- **Financial:** The department incurred significant costs related to disruption, system restoration, and external consultancy. The ransom was not paid.
- **Operational:** Court activities were severely delayed, affecting legal proceedings and public services nationwide.
- **Reputational:** The breach led to public and professional criticism regarding the government's digital security readiness.
- **Data Exposure:** There is a risk that highly sensitive legal and personal data was exposed, though the full extent remains unclear.

2.8 Lessons Learned & Remediation

- **Short-term:** Immediate password resets, review, and strengthening of backup processes.
- **Medium-term:** Upgrading anti-malware defenses, implementing scheduled vulnerability scans, and improving access controls.
- **Long-term:** Adoption of a Zero Trust security model and regular incident response exercises to build organizational resilience.

2.9 Accountability

An internal investigation is ongoing, with possible disciplinary action for those found negligent. No whistleblowers have been identified in this case.

3. Comparative Analysis

Both incidents involved ransomware attacks that exploited a combination of technical vulnerabilities, weak processes, and human error. While Transnet's breach had a more pronounced economic impact due to its role in logistics, the DoJ&CD breach raised serious concerns about the protection of sensitive legal data and the continuity of public services.

Category	Transnet SOC Ltd	Dept. of Justice & CD
Industry	Transport, State-Owned	Government, Legal
Incident Type	Ransomware, Operational	Ransomware, Data Breach
Detection	Internal, after outage	Internal, immediate
Disclosure	Within 24 hours	Within 3 days
Regulations	POPIA, King IV, ISO 27001	POPIA, MISS
Root Causes	Phishing, unpatched systems	Weak passwords, outdated AV
Impact	Major financial, operational	Major operational, reputational
Leadership	CSO resigned	IT Director suspended
Data Exposure	Limited	Potentially significant
Remediation	Patch, segment, train	Passwords, backups, Zero Trust

Both organizations demonstrated a willingness to be transparent, but the speed and effectiveness of their responses varied. Transnet's leadership changes and rapid public disclosure helped manage the crisis, while the DoJ&CD's delayed communication and ongoing investigation have left some questions unanswered.

4. Recommendations & Prioritized Remediation Roadmap

To address the vulnerabilities exposed by these incidents and to build a more resilient security posture, the following actions are recommended:

Timeline	Action	Owner	Description
Short-term	Patch & update all critical systems	IT Security Lead	Complete audit and patch within 30 days
Short-term	Enforce password resets & MFA	IT Operations	Immediate reset and enable multi-factor authentication
Medium-term	Cybersecurity awareness training	HR & IT	Launch quarterly mandatory training
Medium-term	Test and update incident response	Risk/Compliance	Bi-annual exercises and plan improvements
Long-term	Zero Trust security model	CIO/CTO	Plan and implement over 24 months
Long-term	Annual policy review & update	Board/Compliance	Align with POPIA & ISO 27001; review every 12 months

Key Points for Executives:

- **Ownership:** Assign clear responsibility for each action to ensure accountability.
- **Timelines:** Set realistic but ambitious deadlines to drive progress.
- **Continuous Improvement:** Treat cybersecurity as an ongoing process, not a one-time project.

5. Conclusion

The Transnet and Department of Justice incidents are stark reminders that cyber threats are not only technical challenges but also business and governance issues. Both organizations suffered significant disruption, financial loss, and reputational damage due to a combination of outdated technology, weak processes, and insufficient human awareness. For executive leadership, the path forward is clear: invest in modern security infrastructure, foster a culture of vigilance, and ensure that policies and procedures are regularly reviewed and tested. By taking these steps, organizations can better protect themselves, their stakeholders, and the broader South African community from future cyber threats.

References & Links:

- [Transnet Annual Report 2022/23](#)
- [DoJ&CD Ransomware Attack Update](#)
- [POPIA Official Document](#)
- [Cybercrimes Act](#)
- [King IV Summary](#)
- [AJIC: Transnet Case Study](#)

PowerPoint presentation



Comparative Incident & Security Breach Analysis

Prepared for Executives

Student: Shirizane Magadla
Student ID: 2025/GRC/10280
Course: GRC104 - Compliance Frameworks and Legal Requirements
Instructor: Miss Sharon
Date: November 8, 2025

Analysis of Major South African Cybersecurity Incidents

Introduction: Why Cybersecurity Incident Analysis Matters

Strategic Importance for Executive Leadership

- Cyber threats pose existential risks to organizational continuity
- Financial losses can exceed R1 billion per incident (Transnet: R1.7B)
- Reputational damage affects stakeholder trust and market position
- Regulatory compliance failures expose organizations to legal penalties

This Analysis Will Deliver:

- ✓ Proactive analysis enables prevention, swift measures, and risk mitigation
- ✓ Root cause analysis identifying technical, process, and human factors
- ✓ Comparative insights revealing common vulnerabilities and patterns
- ✓ Actionable recommendations for strengthening organizational resilience

Case Study 1: Transnet SOC Ltd Ransomware Attack (2023)

Organization Profile

- South Africa's largest state-owned logistics company
- 55,000 employees managing ports, railways, pipelines
- Critical infrastructure supporting the national economy

Incident Timeline & Response

July 2023: Sophisticated ransomware attack launched
Attack Vector: Phishing email → lateral network movement
Detection: Internal, after port operations failed
Disclosure: Within 24 hours (transparent approach)
Response: System isolation, external experts engaged

Critical Impact Analysis

Financial: >R1.7 billion in direct/indirect losses
Operational: Major port shutdowns, supply chain disruption
Reputational: International partner trust erosion
Leadership: CSO resignation, new CISO appointed
Regulatory: Ongoing investigations (no fines yet)

Root Cause Analysis

Technical: Unpatched vulnerabilities, weak network segmentation, inadequate EDR tools
Process: Outdated incident response plan, insufficient testing, and drills
Human: Successful phishing attack, inadequate security awareness training

Department of Justice & Constitutional Development Data Breach (2022)

Organization Profile

- National government department (22,000 employees)
- Responsible for justice administration & court operations

Incident Timeline & Response

•September 2022: Ransomware attack disrupted court systems
•**Attack Vector:** Weak passwords & outdated anti-malware
•**Detection:** Internal, immediate (staff lost system access)
•**Disclosure:** 3 days later (delayed public communication)
•**Response:** Password resets, backup restoration, consultants

Critical Impact Analysis

•**Financial:** Significant disruption & recovery costs
•**Operational:** Nationwide court delays, legal proceedings halted
•**Data Risk:** Potential exposure of sensitive legal data
•**Leadership:** IT Director suspended pending investigation
•**Regulatory:** Under review, no fines issued (yet)

Root Cause Analysis

•**Technical:** Weak password policies, outdated anti-malware software, incomplete backups
•**Process:** Lack of regular vulnerability assessments, inadequate backup/recovery procedures
•**Human:** Limited cybersecurity training, no regular security drills or preparedness exercises

Comparative Analysis: Patterns & Insights		
Side-by-Side Comparison		
Category	Transnet SOC Ltd	DoJ & Constitutional Dev
Industry Sector	Transport/Logistics (SOE)	Government/Legal Services
Attack Type	Ransomware + Operational	Ransomware + Data Breach
Attack Vector	Phishing → Network Lateral Movement	Weak passwords + Outdated AV
Detection Method	Internal (after outage)	Internal (immediate)
Disclosure Timeline	Within 24 hours	Within 3 days
Financial Impact	>R1.7 billion confirmed	Significant (undisclosed)
Data Exposure Risk	Limited exposure	High risk potential
Leadership Response	CSO resigned	IT Director suspended
Regulatory Status	Under investigation	Under review
Critical Patterns & Executive Insights		
•✓ Both incidents involved ransomware attacks exploiting fundamental security weaknesses. •✓ Human factors played critical role: social engineering (Transnet) vs. weak passwords (DoJ&CD). •✓ Response transparency varied: Transnet's rapid disclosure vs. DoJ&CD's 3-day delay. •✓ Leadership accountability: Both organizations took decisive action against IT leadership. •✓ Common vulnerabilities: Inadequate training, outdated systems, insufficient incident preparedness.		

Strategic Recommendations for Executives
IMMEDIATE ACTIONS (0-90 days) - CRITICAL •Patch & update all critical systems (Complete audit within 30 days) •Enforce password resets & enable multi-factor authentication immediately •Deploy advanced endpoint detection and response (EDR) tools •Conduct emergency cybersecurity awareness training for all staff
MEDIUM-TERM INITIATIVES (3-12 months) - HIGH PRIORITY •Redesign network segmentation and implement Zero Trust architecture •Establish bi-annual incident response exercises and plan updates •Implement continuous vulnerability assessment and management programs •Launch quarterly mandatory cybersecurity training programs
LONG-TERM STRATEGY (12+ months) - SUSTAINABLE RESILIENCE •Comprehensive legacy system modernization and ISO 27001 full alignment •Establish continuous security monitoring and threat intelligence capabilities •Annual policy review & update cycle aligned with POPIA & regulatory requirements •Build cybersecurity governance into board-level risk management framework

Conclusion: Key Takeaways & Next Steps

- **Executive Summary: Critical Lessons Learned**

1. **Cyber threats are business-critical risks requiring executive-level attention and investment**
2. **Both incidents demonstrate that fundamental security weaknesses can have catastrophic consequences**
3. **Human factors (training, awareness, processes) are as important as technical controls**
4. **Rapid, transparent incident response and communication are essential for managing crises**
5. **Leadership accountability and decisive action are crucial for organizational recovery and trust**

- **Immediate Executive Actions Required**

- ✓ Board-level cybersecurity risk assessment and strategy session within 30 days
- ✓ Assign a dedicated executive sponsor for the cybersecurity transformation program
- ✓ Allocate budget for immediate critical security improvements and staff training
- ✓ Establish quarterly cybersecurity reporting to the board and the executive committee
- ✓ Engage external cybersecurity experts for independent assessment and guidance